A FIELD GUIDE TO SECURITY HYPE

So It Has a Logo

Time to use the Joshua Tree

A tongue-in-cheek (but load-bearing) triage chart for when the hype hits Slack before the advisory does.

START: An exec just forwarded you an article. It has a name, a logo, and a website.

No: they'll forward you another article within the hour

try again

Is the source real?

Screenshot → LOOP
Find the primary source. *"My nephew in cyber" is not a CVE.*

Real

Do we run the affected thing?

No → **Did you check, or just feel it?**

I felt it → LOOP
Go check. *"Pretty sure" is not an asset inventory.*

go check

I checked → CALM DOWN
Reply-all "not affected." Attach receipts. *Enjoy the 4 minutes of peace before the next one.*

Vendor → **Has the vendor said anything?**

Crickets → LOOP
Email their security team. *Refresh their status page like it owes you money.*

Yes → CALM DOWN
Follow their guidance. *Screenshot it for the auditors. Keep the screenshot for blame purposes.*

We run it

Internet-facing, no login needed?†

No → NORMAL CADENCE
Fix it on the normal cadence like a civilized person. *Write it in the ticket so nobody stops you in the hallway about it.*

Yes, or not sure

Is it actually being exploited?*

No → THIS WEEK
Fix it this week. Close the 14 Slack threads asking about it. *Ignore the 15th.*

Yes

Any sign they're already in?

Yes → INCIDENT
Congrats, this is an incident now. Call IR. *Do NOT reply-all.*

Dunno → **Do we even log that?**

No → INCIDENT
Assume yes. Call IR. *Then add "logging" to next year's budget request in 72pt font.*

Yes → LOOP
Go read the logs. *Then come back and answer honestly.*

No

Is there a fix you can install?

No → MITIGATE
Mitigate. WAF rule, kill the feature, or unplug it on purpose. *Controlled panic beats the regular kind. Vendor appliance? Open a ticket and enjoy the hold music.*

Yes

Who owns it?

Nobody → PLOT TWIST
Nobody, or the guy who left in 2019? *Congratulations, it's yours now.*

Someone still here

Will fixing it break prod?

No idea → LOOP
Test it in staging. *"Prod on a Friday" is not staging.*

Yes → TONIGHT
Mitigate now. Book a maintenance window for tonight. *Try to expense the pizza.*

No → ALL HANDS
Drop everything and push it to every endpoint with PDQ before your 2pm notices. *Your reward: a ticket blaming you for the 3rd floor printer.*

CHECK ALL THAT APPLY

The Hype Meter

- [ ] Has a logo
- [ ] Has its own website
- [ ] Name ends in -Shell, -Bleed, or -Heart
- [ ] Mentions "AI" for no clear reason
- [ ] Your mom texted you about it
- [ ] A vendor invited you to a webinar about it within 2 hours *(Hi, ironic, isn't it?)*
- [ ] The CEO used "zero-day" correctly *(Rare.)*

0 Effect of your Hype Meter score on any decision on this chart.

THE FINE PRINT

* "Exploited" means it's on CISA KEV, the vendor confirmed it, or there's a working public PoC. Your LinkedIn feed doesn't count.

† "Not sure" counts as yes.

Wherever you land, write down how you know. Future You is also an auditor.

Wherever you landed, one last box:

Did leadership hear it from you first?

Yes → DONE (FOR NOW)
Log off. You've earned it. *Until the next one gets a logo.*

The Joshua Tree, v1.0. Brought to you by people who patch things for a living. Not legal, financial, or incident response advice. Batteries not included.

A COMPANION TO THE JOSHUA TREE

Exec Whispering

Translating security hype for leadership

The Joshua Tree tells you what to do. This tells you what to say, to whom, and how often, so leadership hears it from you before they hear it from a push notification.

First, some empathy (we know, gross)

Your exec isn't panicking because they're dumb. They're panicking because:

- They heard about it from a push notification, a board member, and their brother-in-law who "works in cyber" (he sells firewalls) before they heard from you.
- They're accountable for risk they can't see. Which, to be fair, is how we feel about the marketing department's SaaS stack.
- "Critical remote code execution" sounds exactly as bad as it is.

Under every "are we vulnerable?" is the real question: **"Do I need to worry, and what do I say if someone asks me?"** Answer that, and the panic has nowhere to go.

> **We nod along about EBITDA. They nod along about use-after-free. Everybody's bluffing.**
>
> The winner is whoever bluffs least and sends updates on time.

WHEN THE ARTICLE LANDS

The first 30 minutes

The first update beats the best update.

- **Acknowledge within 30 minutes,** even if all you know is that you're checking. Silence gets filled with forwarded articles.
- **Give a time for the next update, then hit it.** Execs tolerate "we don't know yet." They don't tolerate quiet.
- **One voice.** Pick one comms owner. Five engineers in five threads with five theories is how a CVE becomes a crisis.
- **Don't guess severity in message one.** "We're checking" buys you time. "We're probably fine" followed by "we're not fine" spends trust you'll need for the next one. Every reversal teaches leadership to skip your updates and go read the news instead.

EVERY UPDATE, SAME SHAPE

The four-line update

`Status:`	Checking / Not affected / Affected, fixing / Fixed / Incident
`Exposure:`	What's affected, in business terms: "the customer portal," not "php-fpm on web-03"
`Action:`	What we're doing, and by when
`Next update:`	[Time, time zone]

Why it works: execs skim. A consistent format trains them to read line one and exhale. Notice what's missing: no CVSS, no CVE number, no exploit chain. Those go in a link for the one exec who wants to feel technical. (There's always one. He has a Raspberry Pi.)

FROM THE TREE TO THE INBOX

Joshua Tree outcomes: what to tell leadership

WHERE YOU LANDED	TELL THEM	CADENCE	ESCALATE IF
CALM DOWN **Not affected**	"We checked. We don't run it. Here's how we know."	Once	New info changes the picture
CALM DOWN **Vendor's problem**	"[Vendor] is affected and handling it. Our exposure is [X]. We're tracking their guidance."	When the vendor updates	Vendor goes quiet 24h on an exploited bug
NORMAL CADENCE **Not exposed**	"We run it, but it's not internet-facing. Fixing on our normal schedule by [date]."	At completion	Exploitation reports change
THIS WEEK **Exposed, not exploited**	"Exposed, but no active exploitation. Fixed by [date]."	Daily	It lands on CISA KEV
MITIGATE **No fix yet**	"No fix exists yet. We've reduced exposure by [action] and will patch when one ships."	Daily, or on vendor news	Mitigation fails or signs of compromise
TONIGHT **Fix breaks prod**	"Fixing tonight. Expect brief downtime for [service] between [times]."	Before and after the window	The window goes sideways
ALL HANDS **Exploited and exposed**	"Actively exploited and we're exposed. Patching now, done by [time]."	Every 1 to 2 hours	Any sign of compromise
INCIDENT **They're already in**	"We're treating this as a security incident. IR is engaged. Updates every [X] in [channel]."	Per your IR plan	Already escalated. Stop freelancing.

The Incident row is where you stop being clever.

Hand comms to your IR plan, loop in legal, and put down the jokes. Including this doc's.

FIELD TRANSLATION GUIDE

What they say, what they mean, what you say back

THEY SAY	THEY MEAN	YOU SAY
"Are we zero-day'd?"	I learned a word today.	"It's [patched / unpatched] and we [are / aren't] exposed. Here's the four-liner."
"Can't we just turn off PHP?"	Make the scary thing go away.	"Sure. It also turns off the website, which is where the money comes from. Here's the mitigation that doesn't."
"The vendor says we're fine."	Can I stop worrying?	"Great, we're verifying. Vendors are optimistic professionally."
"Why didn't our [expensive tool] catch this?"	I signed that renewal.	"Tools catch attacks, not the existence of bugs. Here's what it *did* see."
"What's our CVSS?"	I need a number to say confidently in the board meeting.	"CVSS rates the bug, not our risk. Our risk: [exposed? exploited?]."
"I read AI can exploit this automatically."	I read an article. Possibly written by AI.	"Exploit speed is up everywhere. That's why our window is [X], not [Y]."
"Let's get everyone on a bridge."	I need to *see* people working.	"Happy to. Engineers stay heads-down fixing; I'll run an update call at [time]."
"Is this the next Log4Shell?"	Will this eat my month?	Compare scope honestly: how many of our systems, how exposed, how fast to fix.
"Do we need to do anything?"	Please say no.	"No." The best word in IT. Use it whenever it's true.
"Can you send me something I can forward?"	Yes. Always yes.	Write every update as if it's going to the board, because it is. Possibly with your typos.

SELF-INFLICTED WOUNDS

Things that make it worse

- **"Not affected" without receipts.** See tree box D1a: feelings are not an asset inventory.
- **Leading with CVSS, CVE IDs, or the exploit chain.** You lost them at "heap."
- **Hedging into soup.** "It is possible that, under certain conditions…" Execs hear "yes, and IT is scared."
- **Fixing it silently.** Unannounced fixes are undocumented heroics, and undocumented heroics don't get budget.
- **Roasting the exec in the team channel.** Screenshots are forever. (Yes, we see the irony in a doc called Exec Whispering.)

Before the next one gets a logo

Most hysteria is a symptom of no agreed playbook. Win the argument before there's a fire:

- **Agree on a severity rubric now.** Exposure plus exploitation, not headlines. (Conveniently, there's a poster.)
- **Agree on a comms SLA.** For example: acknowledge in 30 minutes, four-liner within 2 hours.
- **Name a comms owner and a backup.**
- **Create one standing channel** so updates live there and not in 14 DMs.
- **Know what you run.** Asset inventory is the difference between a 10-minute answer and a 10-hour one. (Yes, we sell tools for that. No, we're not subtle.)
- **Pre-write your templates.** They're on the back page. You're welcome.

After the dust settles

- **Run a 15-minute retro.** How long until the first update? Did the answer change? Who heard about it from the news first?
- **Turn pain into budget.** Fear is a limited-time offer: the logging-budget window closes about 9 days after the headline.
- **Send the all-clear.** Closure is a deliverable too.

BACK PAGE

Copy-paste templates

Fill in the brackets, paste, send. Copy-paste versions live at https://github.com/pdqcom/Bonus-Content/tree/master/Exec-Whispering

1. Holding statement

We're aware of [VULN NAME] in the news. We're checking whether it affects us now. Next update by [TIME]. No action needed from you.

2. Not affected

Status: Not affected
Exposure: None. We don't run [AFFECTED PRODUCT]. Verified by [METHOD].
Action: None needed. We'll watch for changes.
Next update: Only if something changes.

3. Affected, fixing

Status: Affected, fixing
Exposure: [BUSINESS SYSTEM] runs it. [Is / isn't] internet-facing. No signs of compromise.
Action: [Patching / mitigating] by [DATE/TIME]. [Downtime, if any.]
Next update: [TIME]

4. Escalated to incident

Status: Security incident declared
Exposure: Under investigation. IR team engaged.
Action: Following our IR plan. Updates only in [CHANNEL]. Please don't forward or discuss outside it.
Next update: [TIME]

5. All clear

Status: Fixed
Exposure: None remaining. [SYSTEMS] patched and verified on [DATE].
Action: Closed. Retro on [DATE] if you want to join.
Next update: Not needed. Go enjoy the 4 minutes of peace.

Lost? Go back to the tree.

Built by people who patch things for a living. Not legal, financial, or incident response advice.